# EWB COURSES

AI-POWERED CYBERSECURITY

ASSESSMENT 01

# Security foundations



Individual Assessment | 100 marks

Intern Name

**SAHADHAT USMANI CHOUDHURY**

Intern ID

INTERNSHIP_17900692996ab24a33d758f

Batch / Group

AI-powered Cybersecurity

Course Title

1 month online AI-Powered Cybersecurity Internship

Submission Date

30-10-2026

REPORT CONTENTS


A Secure a student account

B Analyse a suspicious message

C Triage a sign-in alert

D Review an AI security answer

# Assessment 01: Security Foundations

EWB Courses | AI-powered Cybersecurity
Name: SAHADHAT USMANI CHOUDHURY
Batch: AI-powered Cybersecurity

## Task A | Secure a Student Account (25 marks)

### Scenario -

Mira uses the same short password for her email and learning portal. She approves unexpected sign-in prompts, postpones device updates and keeps her only project copy on one laptop. A friend sometimes uses that laptop under Mira's signed-in account.

A1. Identify five distinct risks. For each, name the asset at risk and explain how confidentiality, integrity or availability could be affected. (10 Marks)

A2. Give one practical control for each risk. Explain why it helps, including atleast one limitation. Prioritise your first three actions and justify the order. (10 Marks)

A3. Explain authentication versus authorization using Mira’s learning portal as your example. (5 Marks)

### Solution:

### A1-A2. Five risks, Asset, CIA Impact, Control and Limitation. (20 marks)

Confidentiality means keeping information private. Integrity means protecting information from unauthorized changes. Availability means keeping information accessible when it is needed. Mira's habits create the following five distinct risks.

| Risk | Asset | CIA impact | Control | Limitation |
|---|---|---|---|---|
| **Short, reused password** | **Email and Portal Accounts** | **Confidentiality:** If someone cracks her password, her private messages may be read. **Integrity:** Attacker/unauthorized user could tamper her files and submissions and even account settings without permission. | **Different Password:** Use different passwords for each account and keep them safe in a secure password manager, which strengthen her account security. | A strong password would not stop her from being tricked by an attacker with a fake link. |
| **Unexpected MFA approvals** | **Account access and Records** | **Confidentiality and integrity:** Accidentally approving a random Multi-factor Authentication prompt may give an attacker full access to her account. This allows them to snoop through private information and tamper critical data. | **Deny Unexpected Prompt:** Deny random prompts and report them, which protects her device from unauthorized access. | If her device buzzes constantly, she might accidently tap on “Approve”. Being careful is not enough to prevent human error. |
| **Delayed updates** | **Laptop applications and Files** | **Confidentiality, Integrity and Availability:** Postponing updates makes her device vulnerable and leaves her device completely unprotected against attackers. Attackers can exploit these flaws. | **Enable Automatic Update:** Enabling automatic updates and restarting after saving work keeps her device security strong and up to date. | Updates do not fix or protect her from being attacked, and waiting for restart delays her work. |
| **Single project copy** | **Project files** | **Availability:** Relying on a single project copy is extremely risky. If the file gets corrupted or her device is lost, her only project copy would be lost permanently. | **Make Multiple Copies:** Making more than one copy and storing them on a different device prevents data loss and worry, even if her file gets corrupted or her device lost. | Backup files may miss her recent edits on that project, and if her backup drive stays plugged in, it may also be compromised if attackers put a virus into her system. |
| **Friend uses signed-in account** | **Private files and Active sessions** | **Confidentiality:** Even a trusted friend might accidentally look at private files or sensitive data they shouldn’t see. **Integrity:** Any changes, edits, or mistakes made by that friend will be attributed to her. | **Set up Different Account:** Set up a separate user account if someone else needs to use her device, which helps her to protect her project/data. | A separate account does not work if she tells someone her password to her personal account. |

## A2. First Three Priorities and Reason.

If a random notification asks her to approve a login which she didn't initiate, she must deny it immediately and report it to the IT Administration. That notification means someone else is actively trying to get access to her account.

She needs to update her credentials and set different passwords for different accounts because using the same password is risky, if one account has been hacked the hacker can also get access to other accounts/portals.

She needs to make a secure copy of her project file, update her device from time to time and set up a separate account for her friend. Keeping only one copy of project file would be highly risky.

## A2. First Three Priorities and Reason.

* **Authentication (Verifying Identity):** This is the process of proving who you are. For Mira, the learning portal handles this by checking her password and requiring a Multi-factor Authentication (MFA) to confirm that the person trying to login is actually Mira.

* **Authorization (Checking Permission):** It determines what you are allowed to do once you are logged in. For example, Mira's account is authorized to upload her own assignments, but she is blocked from editing other students' grades or accessing administrative controls.

## Task B | Analyze a Suspicious Message (25 marks)

## Scenario -

Your college normally uses campus.example. You receive the message below. All .example addresses are fictional training examples.

## Message evidence

From: Scholarship Desk <awards@campus-awards.example>
Reply-To: help@personal-awards.example
Subject: FINAL WARNING - scholarship expires in 20 minutes

"Your scholarship has been approved. Open https://campus-awards.example/verify immediately and enter your college password and OTP to avoid cancellation. Do not contact the college office because their system is unavailable. Reply with a photo of your identity card to speed up payment."

**Your investigation**

B1. Identify five specific warning signs from the evidence. Quote only the relevant phrase and explain why it needs scrutiny. (10 marks)

B2. Describe a safe verification process using an independently obtained official contact or portal. Explain why HTTPS or a familiar display name alone would not prove the message is genuine. (5 marks)

B3. Write a short response plan for a student who already entered a password and OTP. Include immediate containment, official reporting and follow-up checks. Do not ask the student to send you the password or OTP. (7 marks)

B4. State one important fact you cannot establish from this message alone, and what additional evidence would help. (3 marks)

## Solution:

## B1. Five warning signs (10 marks)

| Relevant quotation | Why it needs scrutiny |
|---|---|
| "awards@campus-awards.example"; "help@personal-awards.example" | The email addresses look different. The sender's name does not match with the real college website/official email. Furthermore, the reply address provided is completely suspicious. |
| "FINAL WARNING"; "expires in 20 minutes" | The attackers highlight a tight and panic deadlines. They want the target to react in a hurry instead of verifying it. |
| "Enter your college password and OTP" | They are trying to get your account access. A real college will never ask for your password and OTPs. If you give them OTP they can hijack your account. |
| "Do not contact the college office" | They do not want you to find out the reality. So, they tell you not to contact with the college office because they know that the real office would expose them. |
| "Reply with a photo of your identity card" | They want your identity. Sending a photo of your ID gives criminals the power to impersonate you online. They can execute crimes with your identity. |

## B2. Safe verification process (5 marks)

1. **Stop all interaction:** Do not click any links, open attachments, reply, or type in login credentials.

2. **Preserve the evidence:** Keep the email intact so you can forward it to the official reporting team to examine common phishing signs.

3. **Use independent channels:** Access the college portal strictly through a trusted URL, never use the links provided in the email.

4. **Directly verify with staff:** Collect official contact details of the scholarship office from the official college directory and ask them whether the award, deadline, and sender are genuine.

5. **Understand technical indicators:** Remember that an HTTPS connection only encrypts communication, it does not prove college ownership or legitimacy. Display names can easily be forged, so always check the full sender domain.

## B3. Response after entering a password and OTP (7 marks)

1. **Assume active compromise:** First, assume your account is already compromised because the attacker gets access immediately with the help of OTP.

2. **Change passwords from a safe device:** Second thing you need to do is to change your password right away using the official portal, but make sure that you are using a safe uncompromised device.

3. **Secure other accounts:** Change credentials on any other service where you reuse the same password.

4. **Deny unexpected login prompts:** Decline any push notifications or new authentication requests that pop up without your prompt.

5. **Report urgently to official IT:** Contact the IT help desk via verified channels, provide them the suspicious email and exact timestamps, but do not share your actual credentials or OTP with anyone during this process not even the IT Department.

6. **Revoke sessions and review security:** Ask IT to immediately terminate active login sessions, revoke authentication tokens, and audit recovery methods and MFA configurations to ensure your settings haven't been tampered.

7. **Perform forensic audits and identity protection:** Finally, you must check sent messages, auto-forwarding rules, and profile changes to revert unauthorized edits, if you shared any ID documents during the scam, inform IT right away so that they can apply extra safeguards to protect your identity.

## B4. Important uncertainty (3 marks)

The email text alone cannot prove a sender is authorized by the college, so you must verify the full email headers and check directly with the scholarship office. However, keep in mind that even if those technical headers prove the sender is real, they still cannot guarantee that the scholarship claim itself is actually genuine.

## Task C | Triage a sign-in alert. (25 marks)

### Scenario -

All times below are IST on 18 October 2026. IP addresses are reserved documentation examples. The lab notes say 192.0.2.10 is the usual classroom egress. A different IP alone is not proof of an attacker.

| Time | Source IP | Event | Result |
|---|---|---|---|
| 09:00 | 192.0.2.10 | Password | Success |
| 09:01 | 192.0.2.10 | MFA | Approved |
| 10:14 | 198.51.100.23 | Password | Failed |
| 10:15 | 198.51.100.23 | Password | Failed |
| 10:16 | 198.51.100.23 | Password | Success |
| 10:17 | 198.51.100.23 | MFA | Denied |
| 10:18 | 198.51.100.23 | MFA | Approved |
| 10:20 | 198.51.100.23 | Session | Created |

**Additional statement:** student07 says, "I did not sign in after 09:05. At around 10:18, I approved a prompt because I thought it could stop the repeated requests.

## Your investigation

C1. Build a four-point timeline connecting the logs and user statement. Distinguish observed events from your interpretation. (8 marks)

C2. Give a likely explanation and one alternative explanation. List two additional checks that could distinguish them. Avoid claiming the source IP identifies a person. (7 marks)

C3. Recommend three prioritised response actions for the authorised IT team. Include preservation of evidence and protection of the account. (6 marks)

C4. Write a 60-100 word incident summary: evidence, uncertainty, priority and next action. (4 marks)

## Solution:

### C1. Four-point timeline (8 marks)

1. **09:00–09:01 — Observed:** The password was accepted, and MFA was approved from 192.0.2.10, the usual classroom IP address.

**Interpretation:** This is consistent with the expected classroom sign-in. However, the IP address alone does not prove who signed in.

2. **10:14-10:16 - Observed**: Two password attempts failed from 198.51.100.23, followed by a successful attempt.

**Interpretation:** This shows that the correct password was eventually entered, but the log does not explain who entered it or how they obtained it.

3. **10:17-10:18 - Observed**: An MFA request was denied, followed by an approval.

**Student's statement:** The student said they had not signed in after 09:05 and approved a prompt around 10:18 because they thought it would stop the repeated requests.

**Interpretation:** This suggests MFA fatigue. However, the log shows only two MFA events, not the full history of repeated requests.

4. **10:20 - Observed**: A session was created from 198.51.100.23.

**Interpretation:** This could mean that an unauthorized person gained access to the account, so it needs urgent investigation. However, the log does not show what was viewed or changed during the session.

### C2. Explanations and additional checks (7 marks)

**Likely explanation:** The most likely explanation is that an unauthorized person used the correct password to sign in. The student then approved the MFA prompt because they thought it would stop the repeated requests. This suggests MFA fatigue, where someone approves an unexpected prompt after receiving repeated requests. However, the logs do not show how the person obtained the password.

**Alternative:** Another possibility is that the student's own device or application signed in again through a different network or VPN, and the student did not recognize the request. Although this explanation fits the student's statement less well, it cannot be ruled out. A different IP address alone does not prove that an attacker was involved or identify a particular person.

**Additional Checks:**

**Check 1:** Compare the sign-in and MFA records: Check the request and session IDs, device details, and application information against the earlier classroom sign-in. This would help establish whether the later activity came from a known device or application.

**Check 2:** Confirm the activity with the student: Ask whether any of their devices or applications were using another network or VPN at that time. Also, review what the new session accessed or changed. Activity the student does not recognize would strengthen the explanation of unauthorized access.

### C3. Three prioritized IT response actions (6 marks)

1. **Contain and preserve in parallel:** First, the authorized IT team should revoke suspicious sessions and access tokens, and temporarily restrict the account if needed. At the same time, they should save the relevant logs, keep the original records secure, and record the times and actions taken. However, collecting evidence should not delay urgent steps to stop further access.

2. **Secure the Account:** Next, the team should verify the student's identity and reset the password. They should also check for and remove any unauthorized recovery details or MFA methods. Where supported, they should use phishing-resistant MFA and explain to the student why unexpected prompts must be denied.

3. **Assess scope and monitor:** Finally, the team should review what the suspicious session accessed or changed and restore any affected account settings. They should also investigate related sign-in attempts and monitor the account for further suspicious activity.

### C4. Incident summary (4 marks)

On 18 October 2026, student07's account recorded two failed password attempts, followed by a successful attempt, an MFA denial and an approval from 198.51.100.23. A session was then created at 10:20 IST. The student said they had not signed in after 09:05 but approved a prompt to stop repeated requests. This suggests possible unauthorized access through MFA fatigue. However, the IP alone does not identify a person, and the password source and session activity remain unknown. The IT team should urgently revoke the suspicious session, preserve logs and review device and account activity.

## Task D | Review an AI security answer (25 marks)

### Scenario: fictional AI output

"The email is safe because it uses HTTPS. The sign-in logs prove that the person using 198.51.100.23 stole the password. MFA prevents every account compromise. Delete the suspicious logs and send the student's password to support so they can test it."

## Your investigation

D1. Identify and correct five unsafe or unsupported claims/actions in this output. Explain each correction using the evidence or a trustworthy reference. (10 marks)

D2. Write a better prompt asking an AI tool to analyse only the synthetic evidence, separate facts from assumptions, avoid requesting secrets and state uncertainty. Do not include real student data. (5 marks)

D3. Write your own corrected 100-150 words security advice. Optional: compare it with an AI tool's output and record what you checked. Tool use is not required for full marks. (6 marks)

D4. Add a short AI-use declaration (tool/purpose or "not used") and two evidence/reference notes supporting your reasoning. (4 marks)

### Solution:

### D1. Five corrections (10 marks)

| Unsafe claim or action | Correction and explanation |
|---|---|
| **The email is safe because it uses HTTPS.** | Just because a site uses HTTPS doesn't mean it's safe—it just means the connection is secure. If the domain looks sketchy and is asking for a password or OTP, you still need to verify it first. |
| **The IP proves a person stole the password.** | An IP address doesn't prove that who actually stole a password. It could be a VPN or a shared network. It's better to call this a 'suspected compromise' rather than stating it as a proven fact. |
| **MFA prevents every compromise.** | MFA isn't perfect. In this case, the student just clicked 'approve' on a random notification they weren't expecting. We should mention using number-matching to stop people from just blindly tapping through fatigue. |
| **Delete suspicious logs.** | Don't delete logs! If you wipe them, you destroy the exact evidence needed to figure out what happened and when. Keep them secure so they can't be messed with. |
| **Send the password to support.** | Never hand over a password or OTP to support staff or an AI tool. Real support teams have their own secure ways to reset accounts without ever needing to know your secret password. |

## D2. Improved AI prompt (5 marks)

"Analyze only the supplied fictional message, synthetic sign-in log, and student statement to identify warning signs and construct a four-point chronological timeline. In your analysis, carefully separate observed telemetry facts from reported statements and inferences. Present one likely explanation for the incident along with one plausible alternative, and specify two distinguishing checks to differentiate between them. You must explicitly state uncertainty and avoid inferring human identity or theft mechanics from an IP address. Provide prioritized response actions for authorized IT that focus strictly on containment and evidence preservation. Never request, handle, or transmit passwords, OTPs, or real student data. Support reasoning with authoritative cybersecurity references (CISA, NIST) and flag unverified assumptions."

## D3. Corrected security advice (6 marks)

The scholarship message should be treated as suspicious rather than completely malicious because it shows clear warning signs like strange web links and urgent deadlines alongside requests for passwords and instructions to avoid the college office. If any login details were entered, the user must immediately go to the official website to change their password and contact the IT team so they can quickly end all active sessions while checking account recovery settings and saving the system logs. Furthermore, even though the login timeline looks like a hacker tried to get in by sending too many notification requests to tire the student out, it does not officially show who the attacker is or how they stole the password since a secure HTTPS link only protects the connection and does not prove the website is real. Because of this, users must reject unexpected login notifications and use stronger security prompts whenever possible, while making sure they never share passwords or codes with online help tools or AI programs and always checking AI advice against official cybersecurity guides like NIST and CISA.

## D4. AI-use declaration (4 marks)

I used **Perplexity AI** to help draft, organize, and format this assignment by using the supplied fictional evidence, but I manually wrote, edited, and expanded the core content myself by using my class notes and **Google Gemini and Google search research**. To ensure complete safety and privacy during this process, no real passwords, login codes, or student account records were ever shared or used with the AI tool.

## Two evidence/reference notes

1. The supplied log shows MFA approval at 10:18 and session creation at 10:20. The student reports mistaken approval, supporting possible MFA fatigue. Neither the IP nor the log establishes the remote user's identity or how the password was obtained.

2. CISA supports layered account protection and phishing-resistant MFA. NIST AI 600-1 discusses confabulation and over-reliance on AI. These sources support checking confident claims against evidence rather than treating AI output as proof.

## References


[1] EWB Courses. Assessment 01: Security foundations. Issued 18 October 2026, pp. 1-4. Supplied assessment and fictional evidence.

[2] CISA. Secure Our World. Account security, phishing, passwords, MFA and updates. Retrieved page marked archived. https://www.cisa.gov/secure-our-world

[3] CISA. Tips to Stay Safe while Surfing the Web, Part 2: Accessing Websites Securely. https://www.cisa.gov/resources-tools/training/tips-stay-safe-while-surfing-web-part-2-accessing-websites-securely

[4] CISA and partners. Phishing Guidance: Stopping the Attack Cycle at Phase One. https://www.cisa.gov/sites/default/files/2025-03/Phishing%20Guidance%20-%20Stopping%20the%20Attack%20Cycle%20at%20Phase%20One%20508.pdf

[5] CISA and partners. Weak Security Controls and Practices Routinely Exploited for Initial Access. https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-137a

[6] NIST. Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile. NIST AI 600-1, July 2024, Sections 2.2 and 2.7. https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf